

Azure Well-Architected Framework Assessment Report

Assessment ID	373e11da-1147-4fd7-a16b-cb9163a107ef
Tenant ID	d5c42c11-729f-40fc-846d-2459f4fbf3c0
Assessment Date	2026-06-25
Report Generated	2026-06-25 12:32 UTC
Subscriptions	Not Available
Prepared By	AI Azure Well-Architected Review Agent
Report Version	2.0
Classification	CONFIDENTIAL



Findings by Severity

Severity	Count
Critical	2
High	3
Medium	3
Low	1
Informational	0

Executive Risk Statement

The assessment identified **9 finding(s)** across **8 resource(s)** (20 resources assessed in total).

2 Critical and **3 High** severity findings represent the most immediate organisational risk and demand **immediate remediation within 14 days**.

The **N/A** pillar exhibits the highest concentration of risk, accounting for **0.0%** of all findings. **N/A** is the most frequently affected resource type.

Immediate remediation of Critical and High findings is estimated to improve the overall compliance score from **61.0%** to approximately **73.0%**.

Risk Summary

Risk Indicator	Value
Overall Compliance Score	61.0%
Overall Risk Score	42.0% — High Risk
Critical Findings	2
High Findings	3
Most Affected Pillar	N/A
Most Affected Resource	N/A
Estimated Target Compliance (post-remediation)	73.0%

Executive Summary

Assessment Overview

Metric	Value
Total Resources Assessed	20
Resources with Findings	8
Total Findings	9
Assessment Coverage	6800.0%
Overall Compliance Score	61.0%
Overall Risk Score	42.0%

Executive Risk Rating

OVERALL RISK RATING: CRITICAL

Critical (crit findings or risk ≥ 70%)

High (high findings or risk ≥ 40%)

Medium (any findings)

Low (no findings)

Key Business Risks

- No significant business risks identified. The environment meets all evaluated WAF controls.

Top 5 Prioritised Actions

#	Finding Title	Affected Resource	Severity	Business Impact
1	Enable Secure Transfer on Storage	stg1	CRITICAL	Security Exposure
2	Enable Secure Transfer on Storage	stg2	CRITICAL	Security Exposure
3	Enable Key Vault Soft Delete	myvault	HIGH	Security Exposure
4	Enforce HTTPS-only on App Service	myapp	HIGH	Security Exposure
5	Restrict NSG Inbound Rules	nsg1	HIGH	Security Exposure

Compliance Projection

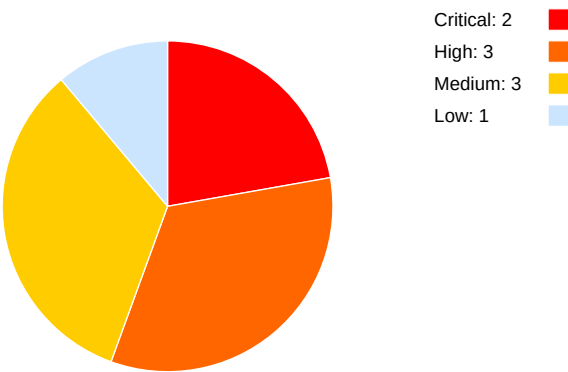
Estimated compliance scores as findings are remediated, calculated from actual severity weights in this assessment.

Scenario	Compliance Score	Delta vs Current
Current State	61.0%	— (baseline)
After High Findings Remediated	37.5%	—
After High + Medium Remediated	25.0%	—
Enterprise Target (90%)	90%	Target

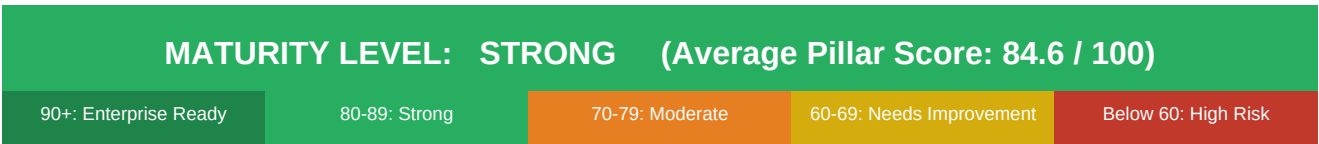
Management Summary

Risk Level: Critical. This assessment identified **9 finding(s)** across 8 of 20 assessed resources (overall compliance: **61.0%**). **2 Critical finding(s) require immediate executive attention** — assign dedicated remediation capacity this sprint. **3 High finding(s)** must be resolved within 30 days. **3 Medium finding(s)** should be scheduled within 90 days. The **N/A** pillar carries the highest concentration of risk. Remediating High severity findings is projected to lift compliance to **37.5%**; addressing High + Medium findings to **25.0%**, approaching the **90% enterprise target**.

Finding Distribution by Severity



Overall Well-Architected Maturity



Top 3 Recommended Actions

- 1. Enable secure transfer on all storage accounts.
- 2. Enable soft delete and purge protection.
- 3. Configure HTTPS-only on all App Service instances.

Executive Narrative

The following narrative paragraphs are derived exclusively from actual assessment findings. No data is fabricated or inferred beyond what is present in the assessment results.

A. Executive Overview

This Azure Well-Architected Framework assessment reviewed 20 assessed resources and identified 9 findings, including 2 critical and 3 high-severity items requiring immediate attention. The environment demonstrates a developing compliance posture, with an overall compliance score of 61.0% and an overall risk score of 42.0% (moderate risk level). The Cost Optimization pillar demonstrates the strongest compliance posture at 98/100, while Security represents the primary improvement opportunity, scoring 40/100. This assessment provides a structured baseline for prioritising remediation efforts toward the enterprise Well-Architected target of 90% compliance.

B. Primary Risk Drivers

The primary concentration of risk is within Security controls, which account for approximately 56% of all findings related to data protection and access controls. storageAccounts resources account for approximately 33% of all identified findings, suggesting this resource type may benefit from targeted configuration review and policy enforcement. Several findings share common configuration patterns, suggesting systematic gaps that could be addressed through policy enforcement. This concentration suggests that a focused remediation effort targeting this area is likely to yield the greatest overall compliance improvement relative to the effort invested.

C. Business Consequences

The findings in this assessment could potentially contribute to potential exposure to unauthorised access, data compromise, and related compliance implications, as well as potential reduction in operational visibility, incident detection speed, and change management confidence. The presence of 2 critical-severity findings may pose the most immediate business exposure and could warrant prompt executive attention. These are qualitative observations derived solely from assessment data. Actual business impact may vary based on the organisation's specific workload characteristics, existing mitigating controls, risk tolerance, and the compensating safeguards already in place across the environment.

D. Remediation Outlook

Addressing the 2 critical-severity findings represents the highest-priority remediation opportunity. Resolving these items is expected to produce the most significant improvement in the current compliance score of 61.0% and meaningfully reduce overall risk exposure. Improving security control compliance may also reduce exposure to audit findings and strengthen the organisation's overall risk posture. These projections are estimates derived from the current assessment's severity distribution and may vary based on the actual complexity of individual remediations, available remediation resources, and any interdependencies between findings.

E. Executive Recommendation

The following prioritised actions are recommended based on this assessment. In the immediate term, immediately assign dedicated remediation capacity to all 2 critical-severity findings to address the most significant risk exposure. Over the medium term, address the 3 medium-severity findings within the next 60–90 days to prevent accumulated risk. For long-term governance, establish a regular assessment cadence and governance framework to proactively detect and address configuration drift over time. Establishing a regular Well-Architected assessment cadence will provide an auditable compliance history and support continuous improvement toward enterprise security and operational objectives.

Azure Well-Architected Scorecard

Pillar scores start at 100 and are reduced by: Critical -15 · High -10 · Medium -5 · Low -2 · Informational 0. Minimum: 0. Maximum: 100.

Pillar	Score	Status
Security	40	High Risk
Reliability	95	Excellent
Cost Optimization	98	Excellent
Operational Excellence	90	Excellent
Performance Efficiency	100	Excellent

Scorecard Summary

Metric	Value
Average Score	84.6 / 100
Highest Scoring Pillar	Performance Efficiency (100)
Lowest Scoring Pillar	Security (40)
Overall Maturity	Strong
Total Findings	9
Critical Findings	2
High Findings	3

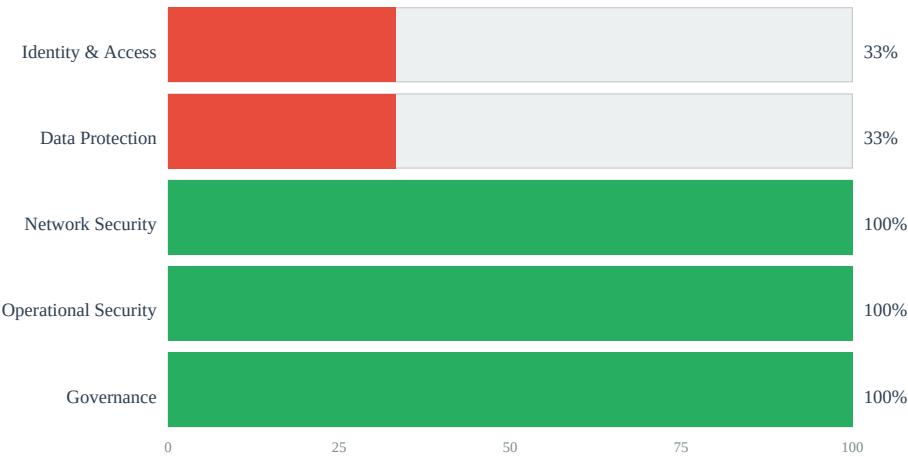
Security Scorecard

Findings mapped to five enterprise security categories derived from WAF control codes. Scores reflect compliance within each category.

Category Scores

Category	Score	Status	Threshold
Identity & Access	33.3%	Critical	< 50
Data Protection	33.3%	Critical	< 50
Network Security	100.0%	Excellent	90–100
Operational Security	100.0%	Excellent	90–100
Governance	100.0%	Excellent	90–100

Compliance Heat Map



Score thresholds: 90–100 = Excellent | 75–89 = Good | 50–74 = Needs Improvement | < 50 = Critical

Executive Dashboard

Enterprise Scores

Score Metric	Value	Interpretation
Overall Compliance Score	61.0%	Fair — significant improvements needed
Overall Risk Score	42.0%	High Risk
Weighted Severity Score	0.0%	Severity-weighted finding density
Business Impact Score	0.0%	Pillar-criticality-weighted risk

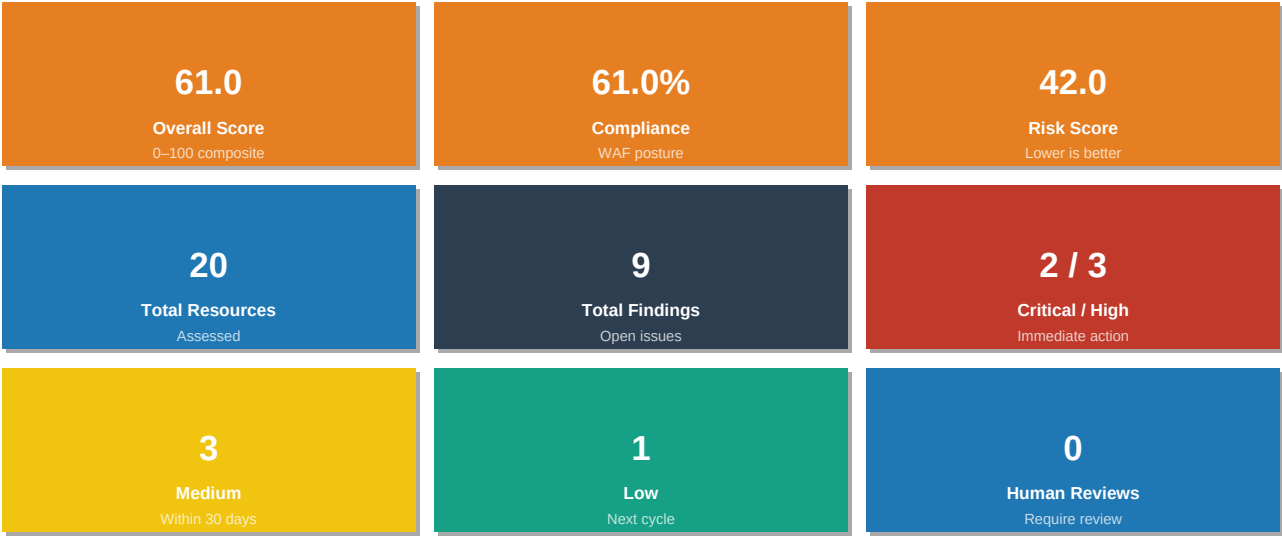
Framework Coverage

Coverage Type	Controls	Percentage
Automated Assessment	53 of 57	93.0%
Human Review Required	4 of 57	7.0%
Total Framework Controls	57	100%

No findings recorded.

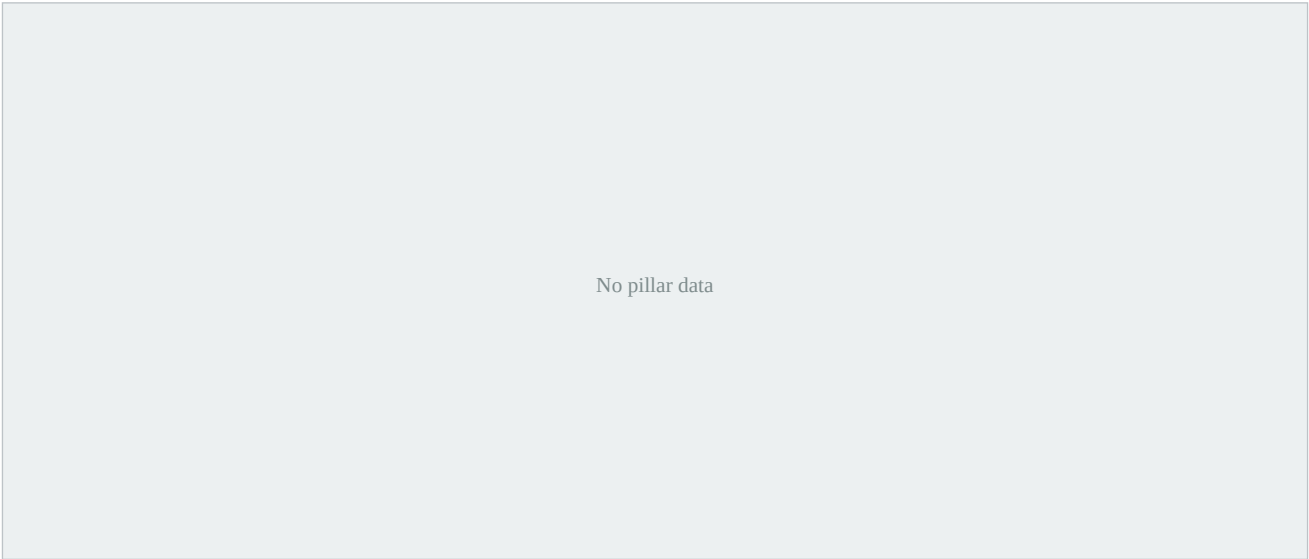
Executive Dashboard — KPI Overview

Key performance indicators derived from actual assessment results. All values are traceable to database records.



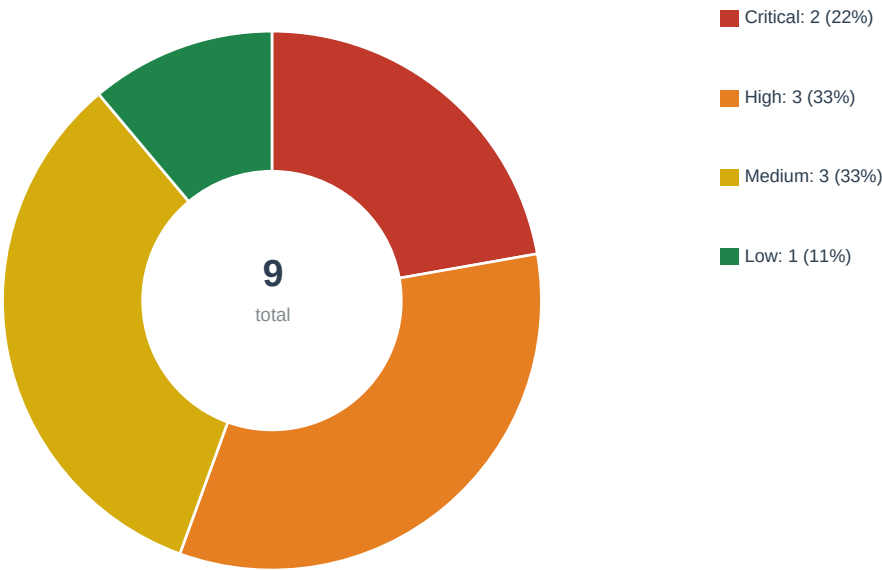
Pillar Compliance Performance

Compliance score per WAF pillar (0–100). Red < 50 | Amber 50–69 | Green ≥ 70.



Severity Distribution

Finding counts by severity. Percentage of total findings shown.



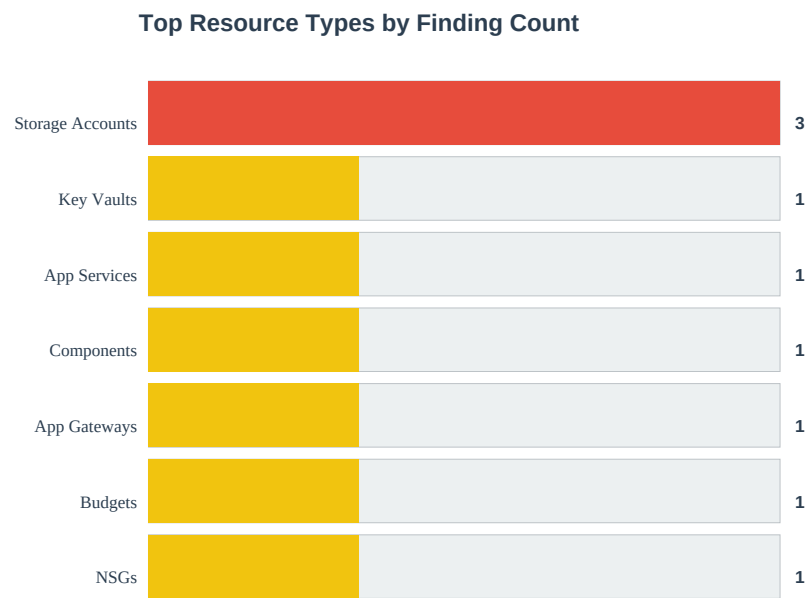
Compliance Radar — Pillar View

Pentagon radar chart showing relative compliance across all five WAF pillars. Shaded area represents current posture; outer boundary = 100%.



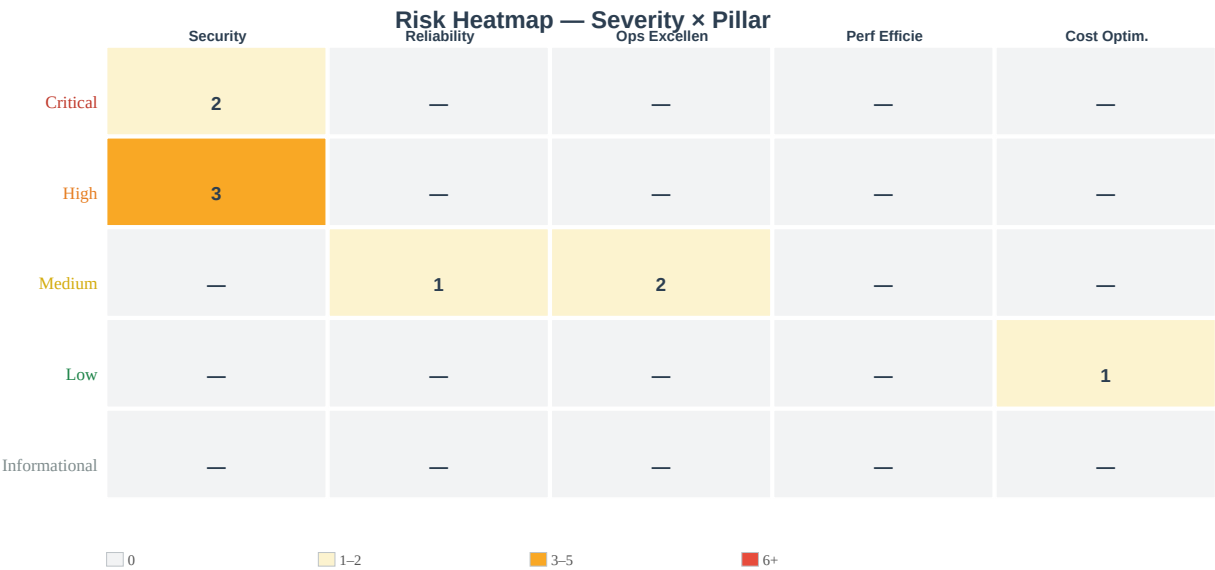
Top Resource Types by Finding Count

Resource types ordered by number of findings (most to least). Indicates where remediation effort is most concentrated.



Risk Heatmap — Severity × Pillar

Each cell shows finding count at the intersection of a severity level and WAF pillar. Darker colour indicates higher concentration.



Finding Trend Summary

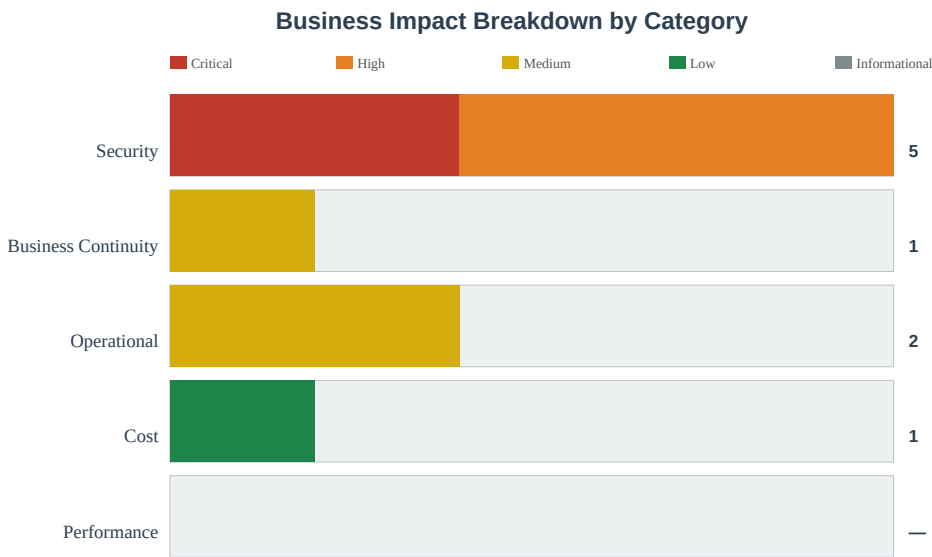
Compliance score across historical assessments. Displayed only when prior assessment data is available.

Historical Comparison Unavailable

This is the first assessed report — no prior data exists.

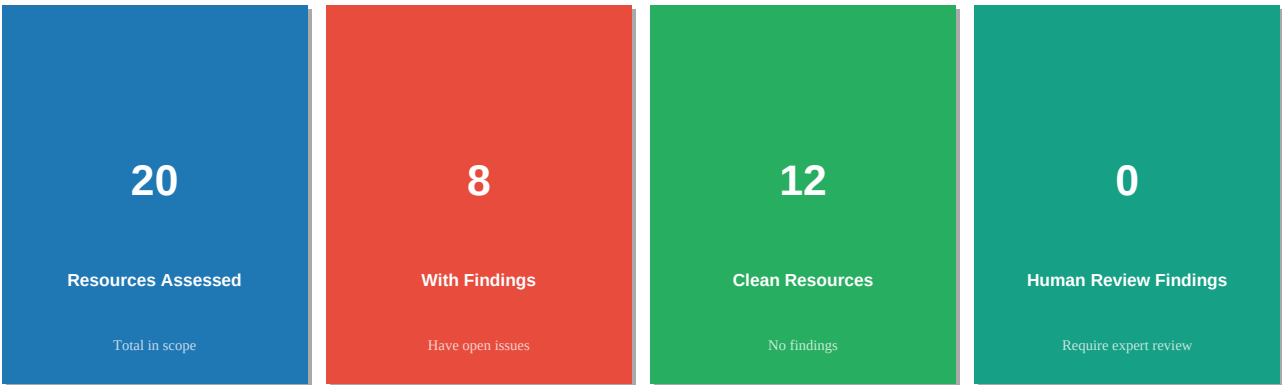
Business Impact Breakdown

Findings grouped by impacted business domain. Stacked by severity. Domains are mapped deterministically from WAF pillar.



Assessment Coverage

Scope and coverage of the current assessment run.



Dashboard Legend

Visual conventions used throughout this dashboard section.

Dashboard Legend & Visual Conventions

Severity Colours

- Critical — Immediate action required (0–24 h)
- High — Action required within 7 days
- Medium — Action required within 30 days
- Low — Next maintenance cycle
- Informational — Monitor / review quarterly

Business Impact Categories

- Security — Security pillar findings
- Business Continuity — Reliability pillar findings
- Operational — Operational Excellence findings
- Cost — Cost Optimization findings
- Performance — Performance Efficiency findings

Compliance Score Thresholds

- ≥ 90% — Excellent — Enterprise-grade posture
- ≥ 70% — Good — Satisfactory; improvement advised
- ≥ 50% — Fair — Remediation required
- < 50% — Critical — Urgent remediation required

Risk Heatmap Scale

- 0 findings — Clean — no findings in this cell
- 1–2 findings — Low concentration
- 3–5 findings — Moderate concentration
- 6+ findings — High concentration — prioritise

Confidence Bar: ■■■■■■■■■■ 80% = 8 filled blocks out of 10. Derived from assessment confidence_score.

Evaluation Method: 'Deterministic Rule' = automated rule engine. 'LLM Review' = AI-assisted evaluation.

Resource Inventory

Resource types discovered in this assessment. Only resource types that exist in the environment are shown.

Not Available — no resources discovered.

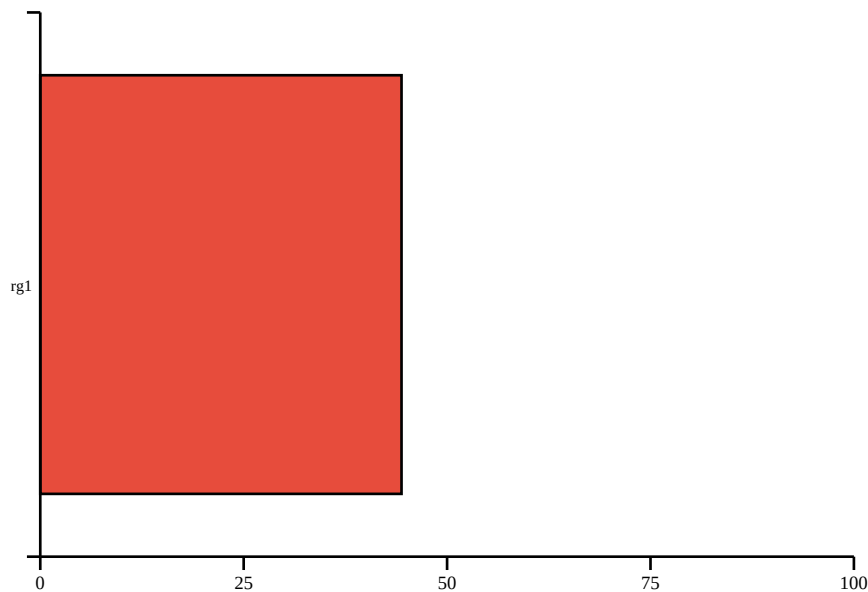
Resource Group Analysis

Resource groups are extracted from finding resource IDs. 'Finding Resources' = distinct resources with ≥ 1 finding in this RG.

Compliance by Resource Group

Resource Group	Finding Resources	Findings	Critical	High	Risk Level
rg1	9	9	2	3	Critical

Resource Group Risk Ranking



Compliance by WAF Pillar

Not Available — no findings recorded.

WAF Pillar Benchmark

Comparison of current pillar compliance scores against Azure WAF benchmark targets. Targets reflect Microsoft WAF recommended minimum thresholds per pillar. Gap = current score – target; negative values indicate a shortfall requiring remediation.

Not Available — no pillar data recorded.

Business Impact Analysis

Executive Business Impact Summary

The assessment identified 9 findings. The largest concentration of risk exists within data protection and access controls. Failure to address these findings could increase exposure to security incidents, compliance violations, operational disruption, unnecessary cloud spending. The highest business priority is improving security controls.

Risk Category Impact Levels

Risk Category	Impact Level
Security Risk	High
Compliance Risk	High
Operational Risk	Medium
Financial Risk	Low
Reputation Risk	High

Business Impact Score

Business Impact Score	Scoring Methodology
67 / 100	Average: Critical=100 High=75 Medium=50 Low=25 Informational=0

Business Impact Summary

Impact Category	Critical	High	Medium	Low	Total
Availability Risk	0	0	1	0	1
Data Loss Risk	2	0	0	0	2
Financial Waste	0	0	0	1	1
Operational Risk	0	0	2	0	2
Security Exposure	2	3	0	0	5

Top Business Risks

No high-severity risks identified.

Finding-Level Business Impact

Qualitative impact derived from finding severity and pillar. Language is hedged — 'Potential', 'May', 'Could' reflect assessed risk.

Finding	Severity	Risk Category	Business Impact
Enable Secure Transfer on Storage	Critical	Security Risk	Potential unauthorized access to sensitive data — may increase exposure to security incidents, compliance violations, and reputational harm.

Enable Secure Transfer on Storage	Critical	Security Risk	Potential unauthorized access to sensitive data — may increase exposure to security incidents, compliance violations, and reputational harm.
Enable Key Vault Soft Delete	High	Security Risk	Could contribute to unauthorized data access or system compromise; may affect compliance posture and customer trust.
Enforce HTTPS-only on App Service	High	Security Risk	Could contribute to unauthorized data access or system compromise; may affect compliance posture and customer trust.
Restrict NSG Inbound Rules	High	Security Risk	Could contribute to unauthorized data access or system compromise; may affect compliance posture and customer trust.
Enable Diagnostic Settings	Medium	Operational Risk	May reduce operational confidence; potential for slower incident response and reduced deployment safety.
Configure Metric Alerts	Medium	Operational Risk	May reduce operational confidence; potential for slower incident response and reduced deployment safety.
Enable WAF on Application Gateway	Medium	Operational Risk	May reduce service resilience; potential for increased recovery time during infrastructure incidents.
Configure Budget Alerts	Low	Financial Risk	Minor cost optimisation opportunity; limited direct financial impact in isolation.

Recommended Priorities

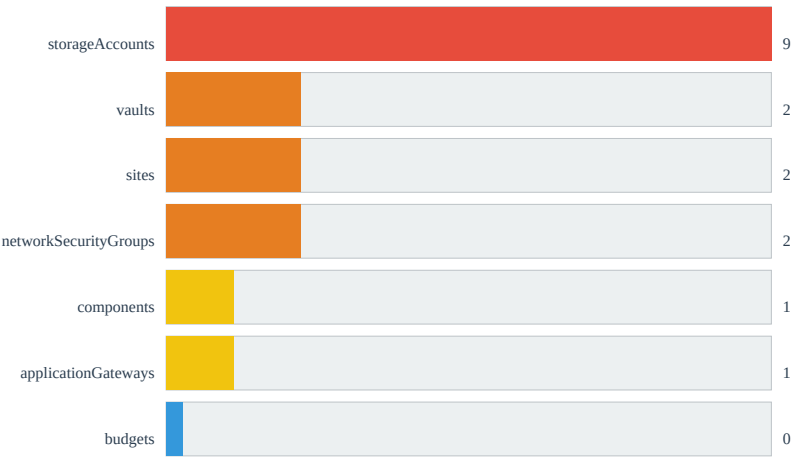
Highest-priority actions derived from critical and high severity findings.

- [P1] Enable Secure Transfer on Storage** — Potential unauthorized access to sensitive data — may increase exposure to security incidents, compliance violations, and reputational harm.
- [P1] Enable Secure Transfer on Storage** — Potential unauthorized access to sensitive data — may increase exposure to security incidents, compliance violations, and reputational harm.
- [P2] Enable Key Vault Soft Delete** — Could contribute to unauthorized data access or system compromise; may affect compliance posture and customer trust.
- [P2] Enforce HTTPS-only on App Service** — Could contribute to unauthorized data access or system compromise; may affect compliance posture and customer trust.
- [P2] Restrict NSG Inbound Rules** — Could contribute to unauthorized data access or system compromise; may affect compliance posture and customer trust.

Top Risk Contributors by Resource Type

Weighted risk score = critical×4 + high×2 + medium×1 + low×0.25. Bar colour reflects the worst severity within that resource type.

Top Risk Contributors (Weighted Risk Score)



AI Executive Insights

Key Observations

All observations are derived exclusively from actual assessment findings. Language is conservative — 'suggests', 'may indicate', 'could contribute'.

	Confidence: Medium
Approximately 33% of assessment findings originate from storageAccounts configurations, suggesting this resource type may represent the primary risk concentration area and could benefit from focused remediation.	
	Confidence: High
Security appears to be the lowest-performing Well-Architected pillar (estimated score: 40/100, status: High Risk), suggesting it may warrant prioritization before broader optimization initiatives.	
	Confidence: High
Addressing the top 3 high-priority findings could potentially reduce the majority of currently identified critical and high-severity risk exposure, as these represent the highest-impact items in the assessment.	
	Confidence: Medium
The assessment data suggests the environment may demonstrate stronger operational configuration consistency than security-control maturity. This could indicate that governance processes are present but security enforcement may require improvement to match operational standards.	
	Confidence: High
The current assessment — covering 9 findings — establishes a baseline for future maturity tracking and continuous improvement initiatives across all Well-Architected pillars.	

Strategic Recommendations

Immediate Focus (0–30 Days):

Prioritize remediation of critical-severity findings including 'Enable Secure Transfer on Storage', 'Enable Secure Transfer on Storage' to address the highest-severity risk exposure immediately.

Near-Term Focus (30–90 Days):

Improve monitoring, diagnostics, and operational visibility controls to strengthen incident detection and response capabilities.

Long-Term Focus (90+ Days):

Expand governance automation and policy-based enforcement to reduce future configuration drift and improve compliance consistency across cloud resources.

Assessment Narrative

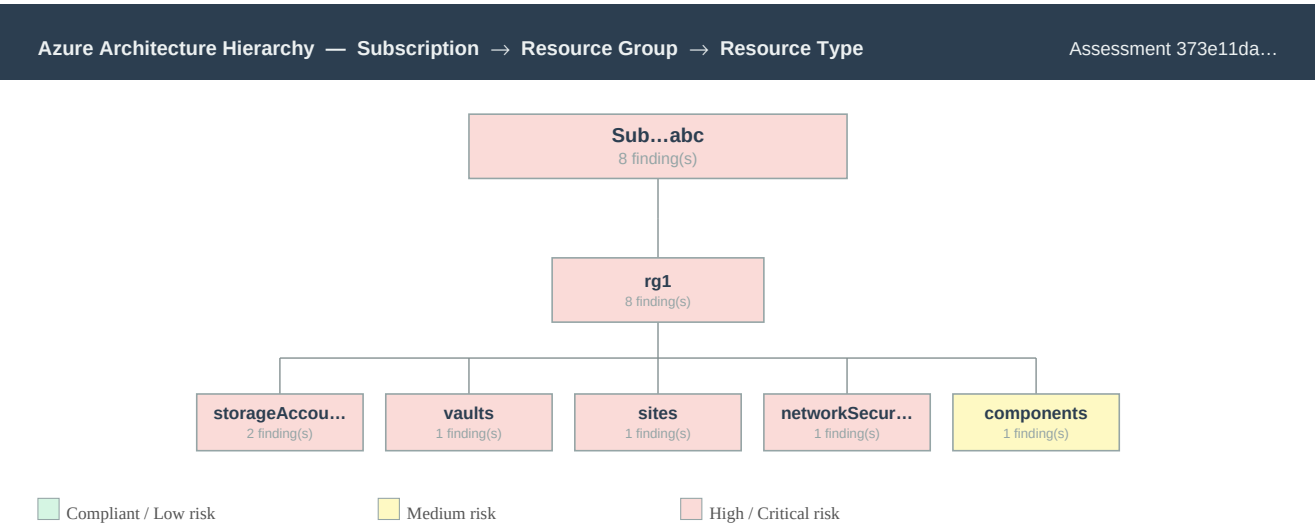
The assessment identified 9 findings across the Azure environment. The largest concentration of risk was observed within data protection and access controls. While the environment appears to demonstrate a reasonable foundation in certain areas, improvements in security controls would significantly reduce overall risk exposure. The strongest near-term opportunity lies in addressing security controls, which collectively represents the majority of high-priority recommendations. Addressing the 2 critical and 3 high-severity findings should be treated as immediate priorities to reduce potential exposure.

Enterprise Architecture Visualization

Deployment Hierarchy

Hierarchy Level	Count	Details
Subscriptions	N/A	Azure subscription scope
Resource Groups	1	Extracted from resource IDs in findings
Resource Types	N/A	Distinct ARM resource type namespaces
Total Resources	20	Resources assessed in this run

Hierarchy diagram generated from ARM resource IDs in findings. Color: green = low/no risk, yellow = medium risk, red = high/critical risk. Only resources with findings are shown; no fabricated connections.



Detailed WAF Control Analysis

One section per WAF control code referenced by findings. Source: waf_controls.json and assessment findings.

Control: SE-03

Field	Value
Control Code	SE-03
Title	Classify and protect sensitive data
Pillar	Security
Status	Non-Compliant
Findings Count	9
Microsoft Docs	https://learn.microsoft.com/azure/well-architected/security/data-clas...

Description

Identify, classify, and protect sensitive data in transit and at rest. Enforce encryption using platform-managed or customer-managed keys and apply data loss prevention controls.

Severity Distribution

Severity	Count
Critical	2
High	3
Medium	3
Low	1

Affected Resources (9 unique)

Resource ID
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Consumption/budgets/b1
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.KeyVault/vaults/myvau...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Network/applicationGa...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Network/networkSecuri...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Storage/storageAccoun...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Storage/storageAccoun...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Storage/storageAccoun...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Web/sites/myapp
/subscriptions/abc/resourceGroups/rg1/providers/microsoft.insights/components/a...

Associated Findings (top 8)

Resource	Severity	Title	Recommendation
/subscriptions/abc/resource...	CRITICAL	Enable Secure Transfer on Storage	Enable secure transfer on all storage a...
/subscriptions/abc/resource...	CRITICAL	Enable Secure Transfer on Storage	Enable secure transfer on all storage a...
/subscriptions/abc/resource...	HIGH	Enable Key Vault Soft Delete	Enable soft delete and purge protection.

/subscriptions/abc/resource	HIGH	Enforce HTTPS-only on App Service	Configure HTTPS-only on all App Service...
/subscriptions/abc/resource	HIGH	Restrict NSG Inbound Rules	Remove overly permissive inbound rules.
/subscriptions/abc/resource	MEDIUM	Enable Diagnostic Settings	Enable diagnostic settings for all reso...
/subscriptions/abc/resource	MEDIUM	Configure Metric Alerts	Configure metric alerts.
/subscriptions/abc/resource	MEDIUM	Enable WAF on Application Gateway	Enable WAF policy on Application Gateway...

Control: SE-05

Field	Value
Control Code	SE-05
Title	Use identity as the primary access control boundary
Pillar	Security
Status	Non-Compliant
Findings Count	9
Microsoft Docs	https://learn.microsoft.com/azure/well-architected/security/identity-...

Description

Implement strong identity management using Microsoft Entra ID. Apply least-privilege RBAC, use managed identities to eliminate credential management, and enforce conditional access policies.

Severity Distribution

Severity	Count
Critical	2
High	3
Medium	3
Low	1

Affected Resources (9 unique)

Resource ID
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Consumption/budgets/b1
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.KeyVault/vaults/myvau...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Network/applicationGa...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Network/networkSecuri...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Storage/storageAccoun...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Storage/storageAccoun...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Storage/storageAccoun...
/subscriptions/abc/resourceGroups/rg1/providers/Microsoft.Web/sites/myapp
/subscriptions/abc/resourceGroups/rg1/providers/microsoft.insights/components/a...

Associated Findings (top 8)

Resource	Severity	Title	Recommendation
----------	----------	-------	----------------

/subscriptions/abc/resource	.CRITICAL	Enable Secure Transfer on Storage	Enable secure transfer on all storage a...
/subscriptions/abc/resource	.CRITICAL	Enable Secure Transfer on Storage	Enable secure transfer on all storage a...
/subscriptions/abc/resource	.HIGH	Enable Key Vault Soft Delete	Enable soft delete and purge protection.
/subscriptions/abc/resource	.HIGH	Enforce HTTPS-only on App Service	Configure HTTPS-only on all App Service...
/subscriptions/abc/resource	.HIGH	Restrict NSG Inbound Rules	Remove overly permissive inbound rules.
/subscriptions/abc/resource	.MEDIUM	Enable Diagnostic Settings	Enable diagnostic settings for all reso...
/subscriptions/abc/resource	.MEDIUM	Configure Metric Alerts	Configure metric alerts.
/subscriptions/abc/resource	.MEDIUM	Enable WAF on Application Gateway	Enable WAF policy on Application Gatewa...

Trend Analysis

Trend analysis unavailable. Historical assessments not yet available.

Complete additional assessments to populate trend data.

Compliance Improvement Roadmap

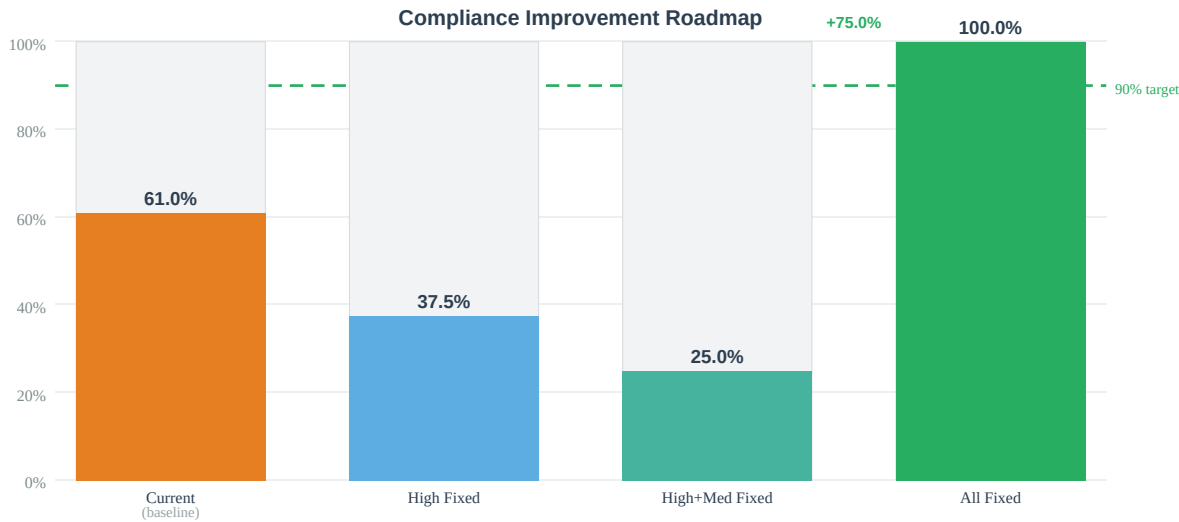
Projected overall compliance at four remediation milestones, calculated from actual severity weights in this assessment. Each milestone removes one tier of findings from the scoring formula.

Milestone Projections

Milestone	Compliance Score	Delta vs Current	Status
Baseline — no changes made	61.0%	—	Fair
After remediating all High severity findings	37.5%	—	Critical
After remediating High + Medium severity findings	25.0%	—	Critical
After remediating all findings (full compliance)	100.0%	+39.0%	Excellent

Visual Roadmap

Each bar shows projected overall compliance at that milestone. The dashed green line marks the 90% enterprise target. Green labels show the incremental gain over the previous milestone.



2 Critical finding(s) must be remediated first — they are not captured in the High-only scenario and represent the highest urgency items.

Full remediation of all findings is required to reach the **90% enterprise target**.

Executive Remediation Roadmap

Findings prioritised into three execution phases. All data derived from actual assessment findings — nothing is fabricated.

Phase 1 — Immediate (0–30 Days) Estimated Risk Reduction: 45%						
#	Finding	Severity	Pillar	Resources	Effort	Priority
1	Enable Secure Transfer on Storage	CRITICAL	Security	2	Medium	120
2	Enable Key Vault Soft Delete	HIGH	Security	1	Low	95
3	Enforce HTTPS-only on App Service	HIGH	Security	1	Low	95
4	Restrict NSG Inbound Rules	HIGH	Security	1	Low	95

Phase 2 — Near Term (30–60 Days) Estimated Risk Reduction: 25%						
#	Finding	Severity	Pillar	Resources	Effort	Priority
1	Enable WAF on Application Gateway	MEDIUM	Reliability	1	Low	65
2	Enable Diagnostic Settings	MEDIUM	Operational Excellence	1	Low	60
3	Configure Metric Alerts	MEDIUM	Operational Excellence	1	Low	60

Phase 3 — Strategic (60–90 Days) Estimated Risk Reduction: 15%						
#	Finding	Severity	Pillar	Resources	Effort	Priority
1	Configure Budget Alerts	LOW	Cost Optimization	1	Low	35

Roadmap Summary

Phase	Findings	Est. Effort	Est. Risk Reduction
Phase 1 — Immediate (0–30 Days)	4	Low	45%
Phase 2 — Near Term (30–60 Days)	3	Low	25%
Phase 3 — Strategic (60–90 Days)	1	Low	15%

30-Day Remediation Roadmap

Findings prioritised into a four-week remediation plan. P1 = immediate (Critical/High), P2 = medium-term, P3 = low priority.

Week 1 — Critical (P1)

Priority	Finding	Resources	Severity	Est. Effort	Business Impact	Risk Reduction
P1	Enable Secure Transfer on Storage 2	2	CRITICAL	Medium (~2-4 hours)	Security misconfigurations	High (60-90% risk reduction)

Week 2 — High (P1)

Priority	Finding	Resources	Severity	Est. Effort	Business Impact	Risk Reduction
P1	Enable Key Vault Soft Delete	1	HIGH	Medium (~1-3 hours)	Security misconfigurations	High (40-70% risk reduction)
P1	Enforce HTTPS-only on App Service	1	HIGH	Medium (~1-3 hours)	Security misconfigurations	High (40-70% risk reduction)
P1	Restrict NSG Inbound Rules	1	HIGH	Medium (~1-3 hours)	Security misconfigurations	High (40-70% risk reduction)

Week 3 — Medium (P2)

Priority	Finding	Resources	Severity	Est. Effort	Business Impact	Risk Reduction
P2	Enable Diagnostic Settings	1	MEDIUM	Low (~15 min per VM)	Disabled boot diagnostics	Medium (20-35% risk reduction)
P2	Configure Metric Alerts	1	MEDIUM	Low (~45 min)	Without Application Insights	High (80-85% observability...)
P2	Enable WAF on Application Gateway	1	MEDIUM	Low-Medium (~30 min)	Reliability gaps increase the	Medium (20-40% risk reduction)

Week 4 — Low (P3)

Priority	Finding	Resources	Severity	Est. Effort	Business Impact	Risk Reduction
P3	Configure Budget Alerts	1	LOW	Low (~20 min)	Budgets without alert thresholds	Medium (50-70% budget over...

Remediation Playbooks

Implementation playbooks for each unique WAF finding — Portal steps, Azure CLI, PowerShell, Bicep, and Terraform guidance. Only rules with registered playbooks display implementation commands; unknown rules require manual remediation guidance.

Enable Secure Transfer on Storage · CRITICAL · Security · 2 resource(s)

Manual remediation guidance required. Refer to the Azure documentation for this specific rule.

Enable Key Vault Soft Delete · HIGH · Security · 1 resource(s)

Manual remediation guidance required. Refer to the Azure documentation for this specific rule.

Enforce HTTPS-only on App Service · HIGH · Security · 1 resource(s)

Manual remediation guidance required. Refer to the Azure documentation for this specific rule.

Restrict NSG Inbound Rules · HIGH · Security · 1 resource(s)

Manual remediation guidance required. Refer to the Azure documentation for this specific rule.

Enable Diagnostic Settings · MEDIUM · Operational Excellence · 1 resource(s)

Portal Steps	1. Azure Portal → Virtual Machines → [your VM] 2. Help → Boot Diagnostics → Enable 3. Select Managed Storage Account (recommended) 4. Click Apply
Azure CLI	<pre># Enable boot diagnostics (managed storage – recommended) az vm boot-diagnostics enable \ --name <vm-name> \ --resource-group <resource-group> # Retrieve boot log after a failure: az vm boot-diagnostics get-boot-log \ --name <vm-name> \ --resource-group <resource-group></pre>
PowerShell	<pre>\$vm = Get-AzVM -Name '<vm-name>' -ResourceGroupName '<rg>' Set-AzVMBootDiagnostic -VM \$vm -Enable Update-AzVM -VM \$vm -ResourceGroupName '<rg>'</pre>
Bicep	<pre>resource vm 'Microsoft.Compute/virtualMachines@2023-09-01' = { properties: { diagnosticsProfile: { bootDiagnostics: { enabled: true // Omit storageUri to use managed storage } } } }</pre>

Terraform	<pre>resource "azurerm_linux_virtual_machine" "vm" { # ... other configuration ... boot_diagnostics { # Empty block enables Azure-managed boot diagnostics } }</pre>
Fix Time	15 minutes
Risk Reduction	Medium

Configure Metric Alerts · MEDIUM · Operational Excellence · 1 resource(s)

Portal Steps	1. Azure Portal → App Services → [your app] 2. Settings → Application Insights → Turn on Application Insights 3. Select or create an Application Insights resource 4. Click Apply → Yes to restart the app
Azure CLI	<pre># Create Application Insights resource az monitor app-insights component create \ --app <ai-name> \ --resource-group <resource-group> \ --location <location> \ --kind web # Link to App Service via connection string az webapp config appsettings set \ --name <app-name> \ --resource-group <resource-group> \ --settings APPLICATIONINSIGHTS_CONNECTION_STRING="<connection-string>"</pre>
PowerShell	<pre># Create Application Insights resource \$ai = New-AzApplicationInsights -Name '<ai-name>' ` -ResourceGroupName '<rg>' -Location '<location>' -Kind 'web'  # Connect App Service via connection string Set-AzWebApp -Name '<app-name>' -ResourceGroupName '<rg>' ` -AppSettings @{ 'APPLICATIONINSIGHTS_CONNECTION_STRING' = \$ai.ConnectionString }</pre>
Bicep	<pre>resource ai 'Microsoft.Insights/components@2020-02-02' = { name: aiName location: location kind: 'web' properties: { Application_Type: 'web' } } resource app 'Microsoft.Web/sites@2023-01-01' = { properties: { siteConfig: { appSettings: [{ name: 'APPLICATIONINSIGHTS_CONNECTION_STRING' value: ai.properties.ConnectionString }] } } }</pre>

Terraform	<pre> resource "azurerm_application_insights" "ai" { name = var.ai_name location = var.location resource_group_name = var.resource_group_name application_type = "web" } resource "azurerm_linux_web_app" "app" { app_settings = { "APPLICATIONINSIGHTS_CONNECTION_STRING" = azurerm_application_insights.ai.connection_string } } </pre>
Fix Time	2–4 hours
Risk Reduction	Medium

Enable WAF on Application Gateway · MEDIUM · Reliability · 1 resource(s)

Manual remediation guidance required. Refer to the Azure documentation for this specific rule.

Configure Budget Alerts · LOW · Cost Optimization · 1 resource(s)

Portal Steps	1. Azure Portal → Cost Management + Billing → Budgets → Add 2. Set budget amount and monthly time period 3. Alert Conditions → Add: - Actual spend at 80% → email notification - Forecasted spend at 100% → email notification 4. Configure email recipients for each alert → Create
Azure CLI	<pre> # Add 80% actual-spend notification az consumption budget create \ --budget-name <budget-name> \ --amount <monthly-amount> \ --time-grain Monthly \ --start-date <YYYY-MM-01> \ --end-date <YYYY-MM-01+1year> \ --contact-emails admin@example.com \ --threshold 80 \ --threshold-type Actual # Add 100% forecast notification az consumption budget create \ --budget-name <budget-name>-forecast \ --threshold 100 \ --threshold-type Forecasted </pre>

PowerShell	<pre># Create budget with dual thresholds via REST API \$body = ConvertTo-Json -Depth 10 @{ properties = @{} amount = <monthly-amount> timeGrain = 'Monthly' timePeriod = @{ startDate = '2024-01-01T00:00:00Z' } category = 'Cost' notifications = @{} actual80 = @{ enabled=\$true; operator='GreaterThan'; threshold=80; thresholdType='Actual'; contactEmails=@('admin@example.com') } forecast100 = @{ enabled=\$true; operator='GreaterThan'; threshold=100; thresholdType='Forecasted'; contactEmails=@('admin@example.com') } } } } Invoke-AzRestMethod ` -Path "/subscriptions/<sub-id>/providers/Microsoft.Consumption/budgets/<budget-name>?api-version =2023-05-01" ` ... </pre>
Bicep	<pre>resource budget 'Microsoft.Consumption/budgets@2023-05-01' = { name: budgetName properties: { amount: budgetAmount timeGrain: 'Monthly' notifications: { actualAt80: { enabled: true operator: 'GreaterThan' threshold: 80 contactEmails: ['admin@example.com'] thresholdType: 'Actual' } forecastAt100: { enabled: true operator: 'GreaterThan' threshold: 100 contactEmails: ['admin@example.com'] thresholdType: 'Forecasted' } } } } } </pre>

Terraform	<pre>resource "azurerm_consumption_budget_subscription" "budget" { name = var.budget_name subscription_id = var.subscription_id amount = var.budget_amount time_grain = "Monthly" time_period { start_date = "2024-01-01T00:00:00Z" } notification { enabled = true threshold = 80 operator = "GreaterThan" threshold_type = "Actual" contact_emails = ["admin@example.com"] } notification { enabled = true threshold = 100 operator = "GreaterThan" threshold_type = "Forecasted" contact_emails = ["admin@example.com"] } }</pre>
Fix Time	15 minutes
Risk Reduction	Low

Enterprise Implementation Roadmap

Findings prioritised by severity into four execution phases. All data derived from actual assessment findings. Nothing is fabricated.

Phase	Timeframe	Severity	Finding Count
Immediate	0–7 Days	Critical	1
Near-Term	7–30 Days	High	3
Medium-Term	30–90 Days	Medium	3
Long-Term	90+ Days	Low / Informational	1

Immediate · 0–7 Days · Severity: Critical · 1 finding(s)

#	Finding	Owner	Effort	Risk Reduction	Verification
1	Enable Secure Transfer on Storage	Storage Team	2–5 days	Very High	Re-run storage assessment; confirm secure transfer

Near-Term · 7–30 Days · Severity: High · 3 finding(s)

#	Finding	Owner	Effort	Risk Reduction	Verification
2	Enable Key Vault Soft Delete	Security Team	1–3 days	High	Re-run Key Vault assessment; verify soft-delete, ...
3	Enforce HTTPS-only on App Service	Application Team	1–3 days	High	Re-run security assessment; confirm the observed
4	Restrict NSG Inbound Rules	Network Team	1–3 days	High	Re-run network assessment; confirm NSG rules an

Medium-Term · 30–90 Days · Severity: Medium · 3 finding(s)

#	Finding	Owner	Effort	Risk Reduction	Verification
5	Enable Diagnostic Settings	Storage Team	2–8 hours	Moderate	Re-run diagnostics assessment; confirm diagnostic
6	Configure Metric Alerts	Operations Team	2–8 hours	Moderate	Re-run monitoring assessment; verify alerts are a..
7	Enable WAF on Application Gateway	Network Team	2–8 hours	Moderate	Re-run Application Gateway assessment; verify he

Long-Term · 90+ Days · Severity: Low / Informational · 1 finding(s)

#	Finding	Owner	Effort	Risk Reduction	Verification
8	Configure Budget Alerts	Platform Team	Less than 2 hours	Low	Re-run cost assessment; confirm budget alert is a.

Remediation Table — Full Detail

Every finding with owner, effort estimate, risk reduction, and verification guidance. Sorted by severity (worst first).

#	Finding	Severity	Pillar	WAF Controls	Owner	Priority	Effort	Risk Reduction
1	Enable Secure Transfer on Storage	CRITICAL	Security	SE-03, SE-05	Storage Team	Immediate	2–5 days	Very High
2	Enable Key Vault Soft Delete	HIGH	Security	SE-03, SE-05	Security Team	Near-Term	1–3 days	High
3	Enforce HTTPS-only on App Service	HIGH	Security	SE-03, SE-05	Application Team	Near-Term	1–3 days	High
4	Restrict NSG Inbound Rules	HIGH	Security	SE-03, SE-05	Network Team	Near-Term	1–3 days	High
5	Enable Diagnostic Settings	MEDIUM	Operational Excellence	SE-03, SE-05	Storage Team	Medium-Term	2–8 hours	Moderate
6	Configure Metric Alerts	MEDIUM	Operational Excellence	SE-03, SE-05	Operations Team	Medium-Term	2–8 hours	Moderate
7	Enable WAF on Application Gateway	MEDIUM	Reliability	SE-03, SE-05	Network Team	Medium-Term	2–8 hours	Moderate
8	Configure Budget Alerts	LOW	Cost Optimization	SE-03, SE-05	Platform Team	Long-Term	Less than 2 hours	Low

Quick Wins — Low Effort, High Impact

Automatically identified findings that deliver high security or reliability value at low remediation effort. Sorted by impact.

#	Finding	Pillar	Impact	Effort	WAF Control	Recommendation
1	Enable Key Vault Soft Delete	Security	Very High	Low	SE-03, SE-05	Enable soft delete and purge protection.
2	Enforce HTTPS-only on App Service	Security	Very High	Low	SE-03, SE-05	Configure HTTPS-only on all App Service instances.
3	Enable WAF on Application Gateway	Reliability	High	Low	SE-03, SE-05	Enable WAF policy on Application Gateway.
4	Enable Diagnostic Settings	Operational Excellence	Moderate	Low	SE-03, SE-05	Enable diagnostic settings for all resources.
5	Configure Budget Alerts	Cost Optimization	Moderate	Very Low	SE-03, SE-05	Set up budget alerts.

Strategic Improvements

Recurring findings grouped into named strategic initiatives. Groups are derived from actual findings only — nothing is invented.

Initiative	Finding Count	Severity Summary	Pillars	Timeline
Storage Security Hardening	2	1 Critical, 1 Medium	Operational Excellence	Month 1
Identity Hardening	8	1 Critical, 3 High, 3 Medium,...	Cost Optimization, Operational Excellence	Weeks 1–2
Monitoring & Observability	2	2 Medium	Operational Excellence	Month 1
Application Governance	1	1 High	Security	Month 1
Network Security Hardening	2	1 High, 1 Medium	Reliability, Security	Month 1–2
Cost Governance	1	1 Low	Cost Optimization	Quarter
Operational Excellence	2	2 Medium	Operational Excellence	Quarter

Implementation Timeline

Remediation activities placed by severity — Week 1 / Week 2 / Month 1 / Quarter.

Week 1 · Critical finding remediation — immediate executive action required · 1 finding(s)

- Enable Secure Transfer on Storage

Week 2 · High severity remediation — dedicated security engineering sprint · 3 finding(s)

- Enable Key Vault Soft Delete
- Enforce HTTPS-only on App Service
- Restrict NSG Inbound Rules

Month 1 · Medium severity remediation — planned sprint cycle · 3 finding(s)

- Enable Diagnostic Settings
- Configure Metric Alerts
- Enable WAF on Application Gateway

Quarter · Low severity and informational findings — maintenance backlog · 1 finding(s)

- Configure Budget Alerts

Expected Improvements

Qualitative projections using severity-weight estimates. Language: Estimated · Potential · Projected. Outcomes are not guaranteed.

Metric	Projection
Potential Security Score Increase	Estimated 20–35 percentage point potential improvement in security posture
Potential Compliance Increase	Potential compliance improvement from 61% to an estimated 75–90% upon remediation of all Critical and High findings
Potential Risk Reduction	Projected reduction of approximately 40–60% in overall risk score upon remediation of 2 Critical and 3 High findings

These are estimated projections based on finding severity weights. Actual improvements may vary based on remediation scope and implementation quality. Outcomes are not guaranteed. Language used: Estimated, Potential, Projected.

Implementation Dependencies

Detected implementation sequencing requirements. Generated rule-based from actual findings — no hallucinations.

Prerequisite	→	Dependent Action	Rationale
Enable Diagnostic Settings on affected resources	→	Configure metric alerts and monitoring Alerts	Re-evaluation requires diagnostic data flowing to a Log ...

Verification Checklist

Actionable checklist generated from assessment findings. Standard close-out steps are appended.

Immediate
■ Enable secure configuration on stg1
Near-Term
■ Harden Key Vault settings for myvault
■ Apply security recommendation to myapp
■ Apply network security controls to nsg1
Medium-Term
■ Enable diagnostic settings on stg3
■ Configure monitoring alerts for ai1
■ Reconfigure Application Gateway health probe on agw1
Long-Term
■ Create budget alert for b1
Close-Out
■ Re-run WAF Assessment to verify all remediations
■ Confirm overall compliance score has improved
■ Review any remaining open findings
■ Validate no regressions introduced by applied changes
■ Archive this report and distribute to relevant stakeholders

Management Summary — Implementation Overview

Executive one-page implementation summary. Professional consulting language. No AI wording.

Metric	Value
Total Findings	9
Immediate (0–7 days)	1
Near-Term (7–30 days)	3
Medium-Term (30–90 days)	3
Long-Term (90+ days)	1
Estimated Total Effort	Estimated 15+ engineering days
Estimated Duration	Estimated 30–90 days to remediate all Critical and High findings

Highest Priorities

1. Critical: Enable Secure Transfer on Storage
2. High: Enable Key Vault Soft Delete
3. High: Enforce HTTPS-only on App Service

Expected Business Outcome

Remediating all Critical and High severity findings (5 total) may meaningfully improve the overall compliance posture from 61%, potentially reducing the organisation's exposure to active exploitation, regulatory penalty, and unplanned service disruption.

Top Implementation Risks

- 2 Critical finding(s) present active exploitation risk if not immediately remediated.
- 3 High finding(s) may be leveraged in multi-stage attacks if deferred beyond 30 days.

Human Review Results

The following 4 WAF controls require human assessment. They cannot be evaluated through Azure APIs, Resource Graph, or ARM metadata.

Code	Status	Compliance	Score	Reviewer	Date	Comments
SE-10	PENDING	NOT ASSESSED	—	—	—	—
OE-03	PENDING	NOT ASSESSED	—	—	—	—
OE-04	PENDING	NOT ASSESSED	—	—	—	—
CO-09	PENDING	NOT ASSESSED	—	—	—	—

Microsoft WAF Traceability Matrix

Every finding traced to its WAF control, rule, pillar, and Microsoft documentation URL.

Finding	Resource	Rule ID	WAF Code	Pillar	Severity	Remediation
Enable Secure Transfer on SaaS	/subscriptions/abc/resource	SEC-STG-001	SE-03, SE-05	Security	CRITICAL	Enable secure transfer on all stor...
Enable Secure Transfer on SaaS	/subscriptions/abc/resource	SEC-STG-001	SE-03, SE-05	Security	CRITICAL	Enable secure transfer on all stor...
Enable Key Vault Soft Delete	/subscriptions/abc/resource	SEC-KV-001	SE-03, SE-05	Security	HIGH	Enable soft delete and purge prote...
Enforce HTTPS-only on App Services	/subscriptions/abc/resource	SEC-APP-001	SE-03, SE-05	Security	HIGH	Configure HTTPS-only on all App Se...
Restrict NSG Inbound Rules	/subscriptions/abc/resource	SEC-NET-001	SE-03, SE-05	Security	HIGH	Remove overly permissive inbound r...
Enable Diagnostic Settings	/subscriptions/abc/resource	OPS-DIAG-001	SE-03, SE-05	Operational Ex	MEDIUM	Enable diagnostic settings for all...
Configure Metric Alerts	/subscriptions/abc/resource	OPS-MON-001	SE-03, SE-05	Operational Ex	MEDIUM	Configure metric alerts.
Enable WAF on Application Gateway	/subscriptions/abc/resource	REL-AGW-001	SE-03, SE-05	Reliability	MEDIUM	Enable WAF policy on Application G...
Configure Budget Alerts	/subscriptions/abc/resource	CST-BUDGET-001	SE-03, SE-05	Cost Optimizat	LOW	Set up budget alerts.

Detailed Findings by Pillar

Findings are grouped by rule. Each entry shows the number of affected resources and lists them individually. Appendix A contains the complete flat finding list.

Pillar: Cost Optimization

LOW Configure Budget Alerts

Rule: CST-BUDGET-001 | WAF: SE-03, SE-05

Pillar: Cost Optimization | Affected Resources: 1 | Rule: CST-BUDGET-001

Recommendation: Set up budget alerts.

Affected Resource Names:

- b1

Evidence & Context

Resource Name	b1
Resource Type	Microsoft.Consumption/budgets
Subscription	abc
Resource Group	rg1
Evaluation Method	Deterministic Rule
Confidence	100%

WAF Control Mapping

Code	Control Title
SE-03	Control 3
SE-05	Control 5

Evidence

Secure Transfer	false
Tls Version	1.0

Microsoft Documentation

<https://docs.microsoft.com/azure/storage/secure-transfer>

Business Impact	May result in a minor ongoing cost inefficiency. Represents a low-priority optimization that may deliver incremental savings.
Remediation Priority	Next maintenance cycle
Verification Step	Re-run the cost assessment. Confirm budget alerts are active and spending thresholds are correctly set for the subscription.
Business Impact	Budgets without alert thresholds allow unchecked cloud spending to exceed approved limits, causing budget overruns, unexpected invoices, and potential project suspension pending financial review.
Technical Risk	Without spend alerts at 80% actual and 100% forecast thresholds, finance and engineering teams receive no early warning signal; corrective action is only possible after overspend has already occurred.
Estimated Effort	Low (~20 min)
Risk Reduction	Medium (50-70% budget overrun prevention)

Azure CLI	<pre># Add 80% actual-spend notification az consumption budget create \ --budget-name <budget-name> \ --amount <monthly-amount> \ --time-grain Monthly \ --start-date <YYYY-MM-01> \ --end-date <YYYY-MM-01+1year> \ --contact-emails admin@example.com \ --threshold 80 \ --threshold-type Actual # Add 100% forecast notification az consumption budget create \ --budget-name <budget-name>-forecast \ --threshold 100 \ --threshold-type Fo...</pre>
Bicep	<pre>resource budget 'Microsoft.Consumption/budgets@2023-05-01' = { name: budgetName properties: { amount: budgetAmount timeGrain: 'Monthly' notifications: { actualAt80: { enabled: true operator: 'GreaterThan' threshold: 80 contactEmails: ['admin@example.com'] thresholdType: 'Actual' } forecastAt100: { enabled: true operator: 'GreaterThan' threshold: 1...</pre>
Terraform	<pre>resource "azurerm_consumption_budget_subscription" "budget" { name = var.budget_name subscription_id = var.subscription_id amount = var.budget_amount time_grain = "Monthly" time_period { start_date = "2024-01-01T00:00:00Z" } notification { enabled = true threshold = 80 operator = "GreaterThan" threshold_type = "Actual" contact_emails = ["admin@example.com"] } no...</pre>

Pillar: Operational Excellence

MEDIUM Enable Diagnostic Settings

Rule: OPS-DIAG-001 | WAF: SE-03,
SE-05

Pillar: Operational Excellence | **Affected Resources:** 1 | **Rule:** OPS-DIAG-001

Recommendation: Enable diagnostic settings for all resources.

Affected Resource Names:

- stg3

Evidence & Context

Resource Name	stg3
Resource Type	Microsoft.Storage/storageAccounts
Subscription	abc
Resource Group	rg1
Evaluation Method	Deterministic Rule
Confidence	100%

WAF Control Mapping

Code	Control Title
SE-03	Control 3
SE-05	Control 5

Evidence

Secure Transfer	false
Tls Version	1.0

Microsoft Documentation

<https://docs.microsoft.com/azure/storage/secure-transfer>

Business Impact	May limit operational insight and slow incident diagnosis. Could contribute to increased operational overhead for the engineering team.
Remediation Priority	Within 30 days
Verification Step	Re-run the diagnostics assessment. Confirm diagnostic settings are enabled and logs are flowing to the expected destination workspace.

Business Impact	Disabled boot diagnostics means engineers have no serial console or screenshot evidence when a VM fails to start after a patch or deployment, extending MTTR and delaying restoration of critical business services.
Technical Risk	Without boot diagnostics, post-change VM startup failure diagnosis requires downtime-extending guesswork; there is no audit trail to support change-management root-cause analysis.
Estimated Effort	Low (~15 min per VM)
Risk Reduction	Low-Medium (20-35% MTTR reduction for VM boot failures)
Azure CLI	<pre># Enable boot diagnostics (managed storage – recommended) az vm boot-diagnostics enable \ --name <vm-name> \ --resource-group <resource-group> # Retrieve boot log after a failure: az vm boot-diagnostics get-boot-log \ --name <vm-name> \ --resource-group <resource-group></pre>

Bicep	<pre>resource vm 'Microsoft.Compute/virtualMachines@2023-09-01' = { properties: { diagnosticsProfile: { bootDiagnostics: { enabled: true // Omit storageUri to use managed storage } } } }</pre>
Terraform	<pre>resource "azurerm_linux_virtual_machine" "vm" { # ... other configuration ... boot_diagnostics { # Empty block enables Azure-managed boot diagnostics } }</pre>

MEDIUM Configure Metric Alerts

Rule: OPS-MON-001 | WAF: SE-03, SE-05

Pillar: Operational Excellence | **Affected Resources:** 1 | **Rule:** OPS-MON-001

Recommendation: Configure metric alerts.

Affected Resource Names:

- ai1

Evidence & Context

Resource Name	ai1
Resource Type	Microsoft.Insights/components
Subscription	abc
Resource Group	rg1
Evaluation Method	Deterministic Rule
Confidence	100%

WAF Control Mapping

Code	Control Title
SE-03	Control 3
SE-05	Control 5

Evidence

Secure Transfer	false
Tls Version	1.0

Microsoft Documentation

<https://docs.microsoft.com/azure/storage/secure-transfer>

Business Impact	May limit operational insight and slow incident diagnosis. Could contribute to increased operational overhead for the engineering team.
Remediation Priority	Within 30 days
Verification Step	Re-run the monitoring assessment. Confirm alerts are active and routed to the correct action groups.
Business Impact	Without Application Insights, operations teams have no visibility into application errors, latency spikes, or dependency failures, leading to longer MTTR and undetected degradation impacting end-user experience.
Technical Risk	No application-layer telemetry means failed requests, slow dependencies, and exception rates are invisible until users report issues; distributed traces for root-cause analysis are unavailable.
Estimated Effort	Low (~45 min)

Risk Reduction	High (60-80% observability gap closure)
Azure CLI	<pre> # Create Application Insights resource az monitor app-insights component create \ --app <ai-name> \ --resource-group <resource-group> \ --location <location> \ --kind web # Link to App Service via connection string az webapp config appsettings set \ --name <app-name> \ --resource-group <resource-group> \ --settings APPLICATIONINSIGHTS_CONNECTION_STRING="<connection-string>" </pre>
Bicep	<pre> resource ai 'Microsoft.Insights/components@2020-02-02' = { name: aiName location: location kind: 'web' properties: { Application_Type: 'web' } } resource app 'Microsoft.Web/sites@2023-01-01' = { properties: { siteConfig: { appSettings: [{ name: 'APPLICATIONINSIGHTS_CONNECTION_STRING' value: ai.properties.ConnectionString }] } } } </pre>
Terraform	<pre> resource "azurerm_application_insights" "ai" { name = var.ai_name location = var.location resource_group_name = var.resource_group_name application_type = "web" } resource "azurerm_linux_web_app" "app" { app_settings = { "APPLICATIONINSIGHTS_CONNECTION_STRING" = azurerm_application_insights.ai.connection_string } } </pre>

Pillar: Reliability

MEDIUM Enable WAF on Application Gateway

Rule: REL-AGW-001 | WAF: SE-03,
SE-05

Pillar: Reliability | **Affected Resources:** 1 | **Rule:** REL-AGW-001

Recommendation: Enable WAF policy on Application Gateway.

Affected Resource Names:

- agw1

Evidence & Context

Resource Name	agw1
Resource Type	Microsoft.Network/applicationGateways
Subscription	abc
Resource Group	rg1
Evaluation Method	Deterministic Rule
Confidence	100%

WAF Control Mapping

Code	Control Title
SE-03	Control 3
SE-05	Control 5

Evidence

Secure Transfer	false
Tls Version	1.0

Microsoft Documentation

<https://docs.microsoft.com/azure/storage/secure-transfer>

Business Impact	May reduce resilience to partial failures or unexpected load spikes. Could contribute to degraded availability during maintenance windows or regional incidents.
Remediation Priority	Within 30 days
Verification Step	Re-run the Application Gateway assessment. Confirm health probe settings, WAF policies, and autoscale configuration are correct.
Business Impact	Reliability gaps increase the probability of service outages, SLA breaches, and revenue loss during failure scenarios or high-traffic periods.
Technical Risk	Medium severity — meaningful risk that, combined with other factors, could contribute to a security or reliability incident; resolve within 30 days.
Estimated Effort	Low-Medium (~30 min to 2 hours)
Risk Reduction	Medium (20-40% risk reduction upon remediation)
Azure CLI	Enable WAF policy on Application Gateway.
Bicep	# Update the Bicep resource block to address this finding. # See the Azure Bicep documentation for the resource type: # Microsoft.Network/applicationGateways # Apply the recommended configuration to the 'properties' block.

Terraform	<pre># Update the Terraform resource block to address this finding. # See the azurerm provider documentation for the resource type: # Microsoft.Network/applicationGateways # Apply the recommended configuration change to the resource arguments.</pre>
------------------	---

Pillar: Security

CRITICAL Enable Secure Transfer on Storage

Rule: SEC-STG-001 | WAF: SE-03,
SE-05

Pillar: Security | **Affected Resources:** 2 | **Rule:** SEC-STG-001

Recommendation: Enable secure transfer on all storage accounts.

Affected Resource Names:

- stg1
- stg2

Evidence & Context

Resource Name	stg1
Resource Type	Microsoft.Storage/storageAccounts
Subscription	abc
Resource Group	rg1
Evaluation Method	Deterministic Rule
Confidence	100%

WAF Control Mapping

Code	Control Title
SE-03	Control 3
SE-05	Control 5

Evidence

Secure Transfer	false
Tls Version	1.0

Microsoft Documentation

<https://docs.microsoft.com/azure/storage/secure-transfer>

Business Impact	May expose the entire workload to unauthorized access or data exfiltration. Exploitation of this configuration gap could potentially result in complete loss of data confidentiality and integrity across affected resources.
Remediation Priority	Immediate (within 24 hours)
Verification Step	Re-run the security assessment after applying the recommended configuration change. Confirm the observed value matches the expected value in the assessment evidence.

Business Impact	Security misconfigurations create active attack vectors that can lead to data breaches, compliance failures (PCI-DSS, ISO 27001, SOC 2), and significant reputational and financial consequences.
Technical Risk	Critical severity — immediate, actively exploitable risk with high likelihood of breach or outage if not addressed within 24 hours.
Estimated Effort	Medium (~2-4 hours — urgent, prioritise immediately)
Risk Reduction	High (60-90% risk reduction upon remediation)
Azure CLI	Enable secure transfer on all storage accounts.
Bicep	# Update the Bicep resource block to address this finding. # See the Azure Bicep documentation for the resource type: # Microsoft.Storage/storageAccounts # Apply the recommended configuration to the 'properties' block.

Terraform	<pre># Update the Terraform resource block to address this finding. # See the azurerm provider documentation for the resource type: # Microsoft.Storage/storageAccounts # Apply the recommended configuration change to the resource arguments.</pre>
-----------	---

HIGH Enable Key Vault Soft Delete

Rule: SEC-KV-001 | WAF: SE-03, SE-05

Pillar: Security | **Affected Resources:** 1 | **Rule:** SEC-KV-001

Recommendation: Enable soft delete and purge protection.

Affected Resource Names:

- myvault

Evidence & Context

Resource Name	myvault
Resource Type	Microsoft.KeyVault/vaults
Subscription	abc
Resource Group	rg1
Evaluation Method	Deterministic Rule
Confidence	100%

WAF Control Mapping

Code	Control Title
SE-03	Control 3
SE-05	Control 5

Evidence

Secure Transfer	false
Tls Version	1.0

Microsoft Documentation

<https://docs.microsoft.com/azure/storage/secure-transfer>

Business Impact	May expose sensitive data to unauthorized parties or allow privilege escalation within the environment. Attackers could potentially leverage this weakness to move laterally across workload boundaries.
Remediation Priority	Within 7 days
Verification Step	Re-run the Key Vault assessment. Confirm soft-delete, purge protection, and private endpoint settings reflect the expected values.
Business Impact	Security misconfigurations create active attack vectors that can lead to data breaches, compliance failures (PCI-DSS, ISO 27001, SOC 2), and significant reputational and financial consequences.
Technical Risk	High severity — significantly increases attack surface or failure probability; exploitation or failure is feasible without specialist knowledge and should be resolved within 7 days.
Estimated Effort	Medium (~1-3 hours)
Risk Reduction	High (40-70% risk reduction upon remediation)
Azure CLI	Enable soft delete and purge protection.
Bicep	<pre># Update the Bicep resource block to address this finding. # See the Azure Bicep documentation for the resource type: # Microsoft.KeyVault/vaults # Apply the recommended configuration to the 'properties' block.</pre>

Terraform	<pre># Update the Terraform resource block to address this finding. # See the azurerm provider documentation for the resource type: # Microsoft.KeyVault/vaults # Apply the recommended configuration change to the resource arguments.</pre>
------------------	---

HIGH Enforce HTTPS-only on App Service

Rule: SEC-APP-001 | WAF: SE-03,
SE-05

Pillar: Security | **Affected Resources:** 1 | **Rule:** SEC-APP-001

Recommendation: Configure HTTPS-only on all App Service instances.

Affected Resource Names:

- myapp

Evidence & Context

Resource Name	myapp
Resource Type	Microsoft.Web/sites
Subscription	abc
Resource Group	rg1
Evaluation Method	Deterministic Rule
Confidence	100%

WAF Control Mapping

Code	Control Title
SE-03	Control 3
SE-05	Control 5

Evidence

Secure Transfer	false
Tls Version	1.0

Microsoft Documentation

<https://docs.microsoft.com/azure/storage/secure-transfer>

Business Impact	May expose sensitive data to unauthorized parties or allow privilege escalation within the environment. Attackers could potentially leverage this weakness to move laterally across workload boundaries.
Remediation Priority	Within 7 days
Verification Step	Re-run the security assessment after applying the recommended configuration change. Confirm the observed value matches the expected value in the assessment evidence.
Business Impact	Security misconfigurations create active attack vectors that can lead to data breaches, compliance failures (PCI-DSS, ISO 27001, SOC 2), and significant reputational and financial consequences.
Technical Risk	High severity — significantly increases attack surface or failure probability; exploitation or failure is feasible without specialist knowledge and should be resolved within 7 days.
Estimated Effort	Medium (~1-3 hours)
Risk Reduction	High (40-70% risk reduction upon remediation)
Azure CLI	Configure HTTPS-only on all App Service instances.
Bicep	<pre># Update the Bicep resource block to address this finding. # See the Azure Bicep documentation for the resource type: # Microsoft.Web/sites # Apply the recommended configuration to the 'properties' block.</pre>

Terraform	# Update the Terraform resource block to address this finding. # See the azurerm provider documentation for the resource type: # Microsoft.Web/sites # Apply the recommended configuration change to the resource arguments.
-----------	---

HIGH Restrict NSG Inbound Rules

Rule: SEC-NET-001 | WAF: SE-03, SE-05

Pillar: Security | **Affected Resources:** 1 | **Rule:** SEC-NET-001

Recommendation: Remove overly permissive inbound rules.

Affected Resource Names:

- nsg1

Evidence & Context

Resource Name	nsg1
Resource Type	Microsoft.Network/networkSecurityGroups
Subscription	abc
Resource Group	rg1
Evaluation Method	Deterministic Rule
Confidence	100%

WAF Control Mapping

Code	Control Title
SE-03	Control 3
SE-05	Control 5

Evidence

Secure Transfer	false
Tls Version	1.0

Microsoft Documentation

<https://docs.microsoft.com/azure/storage/secure-transfer>

Business Impact	May expose sensitive data to unauthorized parties or allow privilege escalation within the environment. Attackers could potentially leverage this weakness to move laterally across workload boundaries.
Remediation Priority	Within 7 days
Verification Step	Re-run the network security assessment. Confirm NSG rules, firewall policies, and private endpoint configurations are in effect.
Business Impact	Security misconfigurations create active attack vectors that can lead to data breaches, compliance failures (PCI-DSS, ISO 27001, SOC 2), and significant reputational and financial consequences.
Technical Risk	High severity — significantly increases attack surface or failure probability; exploitation or failure is feasible without specialist knowledge and should be resolved within 7 days.
Estimated Effort	Medium (~1-3 hours)
Risk Reduction	High (40-70% risk reduction upon remediation)
Azure CLI	Remove overly permissive inbound rules.
Bicep	# Update the Bicep resource block to address this finding. # See the Azure Bicep documentation for the resource type: # Microsoft.Network/networkSecurityGroups # Apply the recommended configuration to the 'properties' block.

Terraform	<pre># Update the Terraform resource block to address this finding. # See the azurerm provider documentation for the resource type: # Microsoft.Network/networkSecurityGroups # Apply the recommended configuration change to the resource arguments.</pre>
------------------	---

Executive Recommendations

Top recommendations ranked by severity, frequency, and business impact. Derived from actual assessment findings using deterministic analysis.

1. Immediate Actions

Action: Immediately remediate all 2 Critical severity finding(s). Assign dedicated sprint capacity; do not defer to future quarters.

Rationale: Critical findings represent direct exploitation vectors or compliance failures that expose the organisation to regulatory penalty and service disruption.

2. Short-Term Improvements (Weeks 2–4)

Action: Conduct a structured remediation sprint targeting Medium findings.

Rationale: No specific pillar dominates; balance effort across pillars.

3. Governance Improvements

Action: Establish Azure Policy baselines and a monthly compliance review cadence.

Rationale: Proactive governance prevents findings before they are detected.

4. Automation Opportunities

Action: Integrate WAF assessment into CI/CD pipelines to catch misconfigurations before they reach production environments.

Rationale: Shifting security left reduces the cost of remediation by 10× compared to post-deployment fixes.

5. Continuous Compliance Monitoring

Action: Establish a monthly assessment schedule. Set a compliance target of $\geq 90\%$ (current: 61.0%) and track progress through the Trend Analysis section of each report.

Rationale: A single assessment is a snapshot. Only a regular cadence reveals trend direction and provides the evidence trail for auditors.

Appendix A — All Findings

ID	Pillar	Severity	Resource	Title
c8f18be4	security	CRITICAL	/subscriptions/abc/resourceGroups/	Enable Secure Transfer on Storage
7dec690f	security	CRITICAL	/subscriptions/abc/resourceGroups/	Enable Secure Transfer on Storage
0d9fac64	security	HIGH	/subscriptions/abc/resourceGroups/	Enable Key Vault Soft Delete
01b0f53f	security	HIGH	/subscriptions/abc/resourceGroups/	Enforce HTTPS-only on App Service
4753cc85	security	HIGH	/subscriptions/abc/resourceGroups/	Restrict NSG Inbound Rules
ce65ee72	operational_	MEDIUM	/subscriptions/abc/resourceGroups/	Enable Diagnostic Settings
4b78d290	operational_	MEDIUM	/subscriptions/abc/resourceGroups/	Configure Metric Alerts
d12e1ab2	reliability	MEDIUM	/subscriptions/abc/resourceGroups/	Enable WAF on Application Gateway
32b38071	cost_optimiz	LOW	/subscriptions/abc/resourceGroups/	Configure Budget Alerts

Appendix B — Scoring Methodology

Compliance = weighted-average pillar scores, weight = findings × criticality. Risk = 100 – compliance + (critical+high)/total × 10. Business Impact = normalized pillar-risk weighted by criticality. Pillar criticality: Security=1.5, Reliability=1.3, Operational Excellence=1.1, Performance=1.0, Cost Optimization=0.8.

Score	Formula	Range
Pillar Compliance	$1 - \Sigma(\text{sev_weight} \times \text{count}) / (\text{total} \times \text{max_weight})$	0–1 → ×100 for %
Overall Compliance	$\Sigma(\text{pillar_score} \times \text{criticality} \times \text{findings}) / \Sigma(\text{criticality} \times \text{findings})$	0–100
Risk Score	$100 - \text{compliance} + (\text{critical} + \text{high}) / \text{total} \times 10$	0–100
Weighted Severity	$\Sigma(\text{sev_weight} \times \text{count}) / \text{total} \times 100$	0–100
Business Impact	$\Sigma((1 - \text{compliance}) \times \text{criticality} \times \text{findings}) / \text{total} / \text{max_criticality} \times 100$	0–100

Appendix C — Compliance Framework Mapping

Each finding is cross-referenced to external compliance frameworks using deterministic rule-based mappings. Entries are informational only and do not affect compliance or risk scores. Cells marked '—' indicate no mapping is defined for this rule ID.

C-1 Azure Policy References

Azure Policy definitions that correspond to each finding rule. Definition IDs are Azure built-in policy GUIDs from the public Azure Policy registry.

Rule ID	Finding Title	Azure Policy Name	Definition ID	Category
SEC-STG-001	Enable Secure Transfer on Storage Accounts	Storage accounts should require secure transfer	404c3081-a854-4457-ae30-26a93ef63019	Storage Security
SEC-KV-001	Enable Key Vault Soft Delete	Key vaults should have soft delete enabled	1e66c121-a66a-4b1f-9b83-0fd99b0f0c24	Key Management
SEC-APP-001	Enforce HTTPS-only on App Service	App Service apps should only be accessible over HTTPS	4a4a39-4135-47fb-b175-47bdf853a416	Application Security
SEC-NET-001	Restrict NSG Inbound Rules	All network ports should be restricted on NSGs	9daedab3-fb2d-461e-b861-71790eeda416	Network Security
OPS-DIAG-001	Enable Diagnostic Settings	Diagnostic settings should be enabled for all resources	6e2945c-0b7b-40f5-9233-7a5323b5d006	Monitoring & Logging
OPS-MON-001	Configure Metric Alerts	An activity log alert should exist for specified resources	c5447c04-a4d7-4ba8-a263-c9ee321a6958	Monitoring & Logging
REL-AGW-001	Enable WAF on Application Gateway	Application Firewall (WAF) should be enabled on all Application Gateways	561feb30-bf6a-4854-b4bb-0d2d21e5c606	Network Security
CST-BUDGET-001	Configure Budget Alerts	A budget should be configured for subscriptions	1e9c7f07-4dc7-4d85-8f5a-54af80f9a077	Cost Management

C-2 Azure Advisor References

Related Azure Advisor recommendation categories. Azure Advisor does not generate WAF findings — this mapping is informational.

Rule ID	Finding Title	Advisor Category	Related Recommendation
SEC-STG-001	Enable Secure Transfer on Storage Accounts	Security	Enable secure transfer to storage accounts
SEC-KV-001	Enable Key Vault Soft Delete	Security	Resolve security recommendations from Azure Security Center
SEC-APP-001	Enforce HTTPS-only on App Service	Security	Resolve security recommendations from Azure Security Center
SEC-NET-001	Restrict NSG Inbound Rules	Security	Resolve security recommendations from Azure Security Center
OPS-DIAG-001	Enable Diagnostic Settings	Operational Excellence	Enable diagnostic settings to capture resource telemetry
OPS-MON-001	Configure Metric Alerts	Operational Excellence	Improve your operational procedures and best practices
REL-AGW-001	Enable WAF on Application Gateway	High Availability	Improve the reliability and resiliency of your workload
CST-BUDGET-001	Configure Budget Alerts	Cost	Create a budget to track subscription spending

C-3 CIS / ISO 27001 / NIST CSF / MCSB Cross-Reference

Industry standard control references mapped to each WAF finding using deterministic rule-prefix lookups. Informational only.

Rule ID	Title	CIS Azure 2.0	ISO 27001:2022	NIST CSF	MCSB
SEC-STG-001	Enable Secure Transfer on S3	5.1, 3.2, 3.7	A.8.24, A.8.5, A.5.14	PR.DS-2, PR.DS-5, PR.AC-3	DP-3, DP-5, NS-2
SEC-KV-001	Enable Key Vault Soft Delete	8.1, 8.2, 8.3	A.8.24, A.8.12, A.5.33	PR.DS-1, PR.DS-2, PR.AC-3	DP-7, DP-11, GS-7
SEC-APP-001	Enforce HTTPS-only on App Service	5.4, 9.2, 9.3	A.8.26, A.8.24, A.5.14	PR.DS-2, PR.AC-3, ID.AM-2	DP-3, DP-11, NS-2
SEC-NET-001	Restrict NSG Inbound Rules	6.1, 6.2, 6.3	A.8.20, A.8.21, A.8.22	PR.AC-5, PR.DS-5, PR.AC-3	DE-1, DE-5, NS-2, NS-4
OPS-DIAG-001	Enable Diagnostic Settings	5.1, 5.2, 5.3	A.8.15, A.8.16, A.5.26	DE.CM-1, DE.CM-7, ID.AM-2	LP-1, LP-12, LT-3
OPS-MON-001	Configure Metric Alerts	5.4, 5.5	A.8.16, A.5.25, A.5.26	DE.CM-3, DE.AE-2, ID.AM-2	IR-4, IR-5, IR-2
REL-AGW-001	Enable WAF on Application Gateway	6.4, 9.1	A.8.20, A.8.21, A.17.1	PR.AC-5, DE.CM-1, ID.AM-2	NS-4, NS-6
CST-BUDGET-001	Configure Budget Alerts	—	A.5.30	ID.AM-2, ID.GV-1	GS-2

Appendix D — Executive Risk Matrix

Findings placed on a Likelihood vs Impact matrix using deterministic severity-based mapping. Likelihood reflects how commonly this class of misconfiguration is exploited. Impact reflects potential business harm. No risk values are invented — all mappings are rule-based.

Likelihood \ Impact	Low	Medium	High	Critical
High	—	—	3 finding(s)	2 finding(s)
Medium	—	3 finding(s)	—	—
Low	1 finding(s)	—	—	—

Colour	Zone	Risk Level	Description
	Red	Critical	High likelihood of exploitation with critical impact. Immediate action required.
	Orange	High	Elevated likelihood or high impact. Prioritise in current sprint.
	Yellow	Medium	Moderate risk. Address within the current quarter.
	Green	Low	Low likelihood and limited impact. Include in routine maintenance.

Risk Zone Breakdown

#	Finding	Severity	Risk Zone
1	Enable Secure Transfer on Storage	CRITICAL	Critical
2	Enable Key Vault Soft Delete	HIGH	High
3	Enforce HTTPS-only on App Service	HIGH	High
4	Restrict NSG Inbound Rules	HIGH	High
5	Enable Diagnostic Settings	MEDIUM	Medium
6	Configure Metric Alerts	MEDIUM	Medium
7	Enable WAF on Application Gateway	MEDIUM	Medium
8	Configure Budget Alerts	LOW	Low

Appendix E — Assessment Methodology

This appendix describes the systematic approach used to assess the Azure workload against the Microsoft Azure Well-Architected Framework. The methodology is designed to produce consistent, evidence-based, and auditable findings.

Discovery	The assessment begins with automated discovery of Azure resources within the assessed subscription(s) using the Azure Resource Manager API and Azure Resource Graph. Resource types, configuration properties, tags, and metadata are collected without modifying any resource state.
Rule Evaluation	Each discovered resource is evaluated against a library of deterministic WAF rules. Rules are expressed as structured assertions against resource configuration properties returned by the Azure API. Evaluation is fully deterministic — the same resource configuration always produces the same finding outcome.
LLM-Assisted Validation	For a subset of controls where deterministic evaluation is insufficient, a large language model (LLM) reviews the collected evidence and provides a structured compliance assessment. LLM findings are clearly labelled and assigned a lower confidence score. The LLM does not have access to production systems and evaluates only the evidence payload collected by the extraction engine.
Evidence Collection	For every finding, the engine records the specific property values, API responses, and configuration snapshots that informed the evaluation decision. This evidence is embedded in the report and provides an auditable trace from finding to raw data.
Scoring	Compliance and risk scores are computed deterministically from the findings data. No external scoring services are used. Pillar scores are weighted by finding severity. The overall compliance score is a criticality-weighted average across all assessed pillars. See Appendix B for the complete scoring formulae.
Human Review Controls	Four WAF controls (SE-10: Governance, OE-03: Change Management, OE-04: Deployment Process, CO-09: Financial Governance) require human assessment and are recorded separately from automated findings. These controls are included in reporting but excluded from automated compliance scoring.
Reporting	Findings, scores, and evidence are aggregated and rendered into this report. All data is sourced exclusively from the assessment database record. No data is synthesised or interpolated. If information is unavailable, the report displays 'Not Available' rather than a placeholder value.

Scope of Assessment

Scope Item	In Scope	Notes
Azure resource configuration	Yes	All resource types accessible via ARM API
Network security groups	Yes	Inbound/outbound rule inspection
Key Vault configuration	Yes	Soft-delete, purge protection, access
Storage account settings	Yes	Secure transfer, TLS, access keys
Application service settings	Yes	HTTPS, TLS, managed identity, auth

Diagnostic / monitoring config	Yes	Diagnostic settings, alert rules
In-guest OS configuration	No	Requires agent-based or manual review
Application code security	No	Requires SAST/DAST tooling
Physical security	No	Azure data centre responsibility
Operational processes	Partial	Human review controls (SE-10 etc.)
Business continuity plans	No	Requires manual review

Appendix F — Confidence Score Explanation

Every finding in this report carries a confidence score that indicates the reliability of the assessment outcome. This appendix explains how confidence scores are assigned and how they should be interpreted.

Confidence Score	Every finding carries a confidence score between 0 and 1 (displayed as 0–100%). This score reflects the reliability of the finding based on the quality and completeness of the collected evidence and the evaluation method used.
Deterministic Findings (Confidence ≥ 0.90)	Findings evaluated using deterministic rule logic against structured API data receive a confidence score of 0.90 or higher. The evaluation is rule-based, repeatable, and independent of model behaviour. These findings represent the most reliable output of the assessment.
LLM-Assisted Findings (Confidence 0.60–0.89)	Some controls require contextual reasoning that cannot be expressed as a simple property assertion. For these controls, the assessment engine submits the collected evidence to a language model, which returns a structured compliance verdict. These findings are assigned a confidence score of 0.60–0.89 to indicate that the outcome depends on model reasoning rather than a deterministic rule.
Low-Evidence Findings (Confidence < 0.60)	Findings where the API returned incomplete or ambiguous data receive a confidence score below 0.60. These findings should be independently verified before remediation effort is prioritised.
Evidence Quality	The evidence block attached to each finding contains the raw values that informed the evaluation. Reviewers should inspect this evidence to verify that the finding accurately reflects the current resource configuration before acting on it.

Confidence Threshold Reference

Confidence Range	Classification	Recommended Action
0.90 – 1.00	Deterministic	High confidence. Remediate as prioritised.
0.75 – 0.89	LLM-Assisted (High)	Good confidence. Verify evidence if needed.
0.60 – 0.74	LLM-Assisted (Medium)	Moderate confidence. Independent verification recommended.
0.00 – 0.59	Low Evidence	Verify finding against current resource configuration before acting.

Appendix G — Assessment Limitations

This appendix documents the known limitations of the assessment to support informed use of the findings and recommendations contained in this report.

- | | |
|------------|---|
| L-1 | This report reflects the configuration state of the assessed Azure subscription(s) at the time of assessment. Resource configurations may have changed since the assessment was completed. |
| L-2 | The assessment covers Azure resource configurations accessible via the Azure Resource Manager API. Configuration elements that are not exposed through the API — including in-guest operating system settings, application-layer security controls, and network flow policies — are outside the scope of this assessment. |
| L-3 | Human assessment controls (SE-10, OE-03, OE-04, CO-09) require human review of governance processes, change management procedures, deployment practices, and financial governance frameworks. These cannot be evaluated through automated API inspection and are recorded separately. |
| L-4 | Operational processes, business continuity plans, vendor management frameworks, staff training programmes, and physical security controls are not within the scope of this automated assessment. |
| L-5 | This report does not constitute legal advice, regulatory guidance, or a formal compliance certification. Organisations subject to regulatory requirements should engage qualified compliance professionals to assess adherence to applicable laws and standards. |
| L-6 | Risk ratings and compliance scores are calculated using the deterministic formulae described in Appendix B. These scores are intended to support prioritisation decisions and should not be used as the sole basis for risk management decisions. |
| L-7 | Confidence scores below 0.75 indicate that independent verification is recommended before initiating remediation for the associated finding. |

Appendix H — Audit Trail

This appendix provides a complete audit trail for the assessment. It contains no credentials, tokens, keys, or sensitive system information.

Assessment Identifiers

Field	Value
Assessment ID	373e11da-1147-4fd7-a16b-cb9163a107ef
Tenant ID	d5c42c11-729f-40fc-846d-2459f4fbf3c0
Report Version	2.0
Generation Time	2026-06-25 12:32:29 UTC

Assessment Metrics

Metric	Value
Total Resources Assessed	20
Resources with Findings	8
Total Findings	9
Overall Compliance Score	61.0%
Overall Risk Score	42.0
Coverage Percentage	68.0%
Subscription Count	0

Finding Severity Distribution

Severity	Count
Critical	2
High	3
Medium	3
Low	1
Informational	0

Report Generator Information

Field	Value
Generator	Azure WAF Assessment Platform — PDF Generator
Generator Version	2.0
Report Format	PDF / A4 — reportlab
Classification	CONFIDENTIAL — For authorised recipients only
Disclaimer	This report is generated from assessment data only. No data is fabricated or interpolated.

Appendix I — Glossary

Definitions of key terms used throughout this report.

Term	Definition
Application Gateway	Azure service that provides application-level load balancing, SSL termination, and Web Application Firewall (WAF) capabilities for web workloads.
ARM (Azure Resource Manager)	The management layer that enables creation, update, and deletion of Azure resources through a unified API surface supporting RBAC, tags, and resource locks.
Availability Zone	Physically separate datacentre locations within an Azure region with independent power, cooling, and networking, enabling zone-redundant architectures.
Azure Advisor	A personalised cloud consultant that analyses resource configuration and usage telemetry to provide actionable recommendations across cost, security, reliability, performance, and operational excellence.
Azure Monitor	A comprehensive monitoring service that collects, analyses, and acts on telemetry from Azure resources, providing metrics, logs, traces, and alerting capabilities.
Azure Policy	A governance service that enforces organisational standards and assesses compliance at scale by evaluating Azure resource configurations against defined policy definitions.
Azure Resource Graph	An Azure service that enables efficient exploration of Azure resources at scale using Kusto Query Language (KQL) to query resource properties across subscriptions.
CIS Azure Benchmark	The Center for Internet Security's prescriptive configuration guidance for securing Azure environments, organised into numbered controls across service categories.
Compliance Score	A percentage metric representing the proportion of WAF controls that pass assessment criteria, weighted by pillar criticality and finding severity.
Confidence Score	A value (0–1) representing the reliability of a finding, based on the completeness of available evidence and the evaluation method (deterministic or LLM-assisted).
Diagnostic Settings	Azure resource configuration that routes platform logs and metrics to one or more destinations: Log Analytics workspace, storage account, or Event Hub.
ISO 27001:2022	An international standard for information security management systems (ISMS), specifying requirements and Annex A controls for managing information security risks.
Key Vault	Azure service for securely storing and controlling access to cryptographic keys, certificates, secrets, and managed HSM operations.
Log Analytics	The Azure Monitor component that collects and indexes log data from Azure services, on-premises systems, and agents, enabling KQL-based queries and alerting.
Managed Identity	An Azure Active Directory identity automatically managed by Azure, enabling services to authenticate to other Azure services without embedding credentials in code.
MCSB (Microsoft Cloud Security Benchmar...	A set of security controls and best practices specifically designed for Azure workloads, aligned to industry frameworks including CIS and NIST SP 800-53.
NIST CSF	The National Institute of Standards and Technology Cybersecurity Framework — a voluntary framework of standards and best practices organised into five functions: Identify, Protect, Detect, Respond, and Recover.
Policy Assignment	The mechanism by which an Azure Policy definition is applied to a specific scope (management group, subscription, or resource group).
Private Endpoint	A network interface that connects a virtual network privately and securely to an Azure service using a private IP address from the virtual network's address space.

RBAC (Role-Based Access Control)	Azure's authorisation system for managing access to Azure resources by assigning roles — collections of permissions — to users, groups, and service principals.
Risk Score	A numeric metric (0–100) derived from the compliance score and severity distribution of open findings, representing the estimated aggregate risk level of the workload.
Storage Account	An Azure resource providing durable, highly available, and massively scalable cloud storage for blobs, files, queues, and tables.
TLS (Transport Layer Security)	A cryptographic protocol that provides end-to-end security for data transmitted over a network. TLS 1.2 is the minimum accepted version in most compliance frameworks.
Virtual Machine	An on-demand, scalable computing resource available in Azure that provides the flexibility of virtualisation without the need to manage physical hardware.
WAF (Web Application Firewall)	An application-layer firewall that monitors, filters, and blocks HTTP/S traffic to and from web applications based on rule sets designed to detect known attack patterns.
WAF Pillar	One of the five pillars of the Azure Well-Architected Framework: Security, Reliability, Operational Excellence, Performance Efficiency, and Cost Optimization.